



Autenticação

Segurança em Redes e Sistemas Informáticos

CTeSP em Redes e Sistemas Informáticos

Escola Superior de Tecnologia e Gestão de Águeda

Universidade de Aveiro

2025-26



Identidade e Autenticação

- Uma identidade digital está associada a uma identidade física, a um utilizador
 - Pode também ser uma máquina, um serviço ou qualquer outra entidade
 - Alguns dos dados da identidade digital vão ser usados no processo em que o utilizador (identidade física) prova que é dono da identidade digital
 - Processo de **autenticação**
 - A forma mais simples e comum de associação de uma identidade física a uma identidade digital (**autenticação**) é através de passwords
 - Fácil de implementar pelos prestadores de serviços
 - Menor esforço para o utilizador
 - Outros elementos usados para autenticação dos utilizadores são:
 - Smartcards, certificados digitais
 - Impressões digitais
-



Fatores de Autenticação

- A prova de que uma identidade física é dona de uma identidade digital pode ser feita de várias formas, que se caracterizam por fatores de autenticação
- Os fatores de autenticação mais comuns
 - **Conhecimento:** Algo que conheço
 - Password, PIN, etc.
 - **Posse:** Algo que tenho
 - Smartcard, telemóvel, token
 - **Biométrico:** Algo que sou ou faço
 - Característica física ou comportamental



Autenticação forte

- Combinação de dois ou mais fatores de autenticação
 - Autenticação multi-fator ou 2FA (Two-factor authentication)
- Outros requisitos comuns na autenticação forte
 - Out-of-Band: Autenticação através de mais do que um canal de comunicação
 - Verificação em 2-passos (2-Step Verification): Confirmação através da resposta a um pedido
 - Exemplo, responder com um código enviado para um telemóvel



Algo que sei: Passwords

- Password é um segredo partilhado entre o serviço e o utilizador
 - Faz parte do conjunto de dados da identidade digital armazenada pelo serviço
- Autenticação é feita através de um username e de password
 - Username é o identificador da identidade digital
 - Permite ao serviço identificar o utilizador
 - Password é o segredo partilhado
 - Através do qual o utilizador prova que é o dono da identidade digital
- A autenticação usando username/password não é muito segura
 - Apenas valida se o utilizador conhece algo: a password



Passwords fracas

- Devido a fatores humanos, muitos utilizadores usam passwords fracas:
 - Conveniência
 - Passwords complexas são difíceis de memorizar
 - Pouca sensibilidade para a segurança
- As passwords podem ser fracas por várias razões:
 - Pouco complexas
 - Podem ser derivadas com base no conhecimento sobre o utilizador
 - Reutilização de passwords antigas
- Passwords fracas:
 - Menos de 10 caracteres
 - Apenas usam um grupo de caracteres (números, letras, caracteres especiais)
 - Podem ser encontradas num dicionário
 - Sequências de teclas num teclado (qwerty, qwe123, ...)
 - Com dados pessoais do utilizador
 - Com referência ao serviço ou aplicação (adobe123)



Passwords seguras

- Não incluem dados sobre o utilizador
- Não incluem palavras de um dicionário
- Pelo menos 12 caracteres de comprimento
- Inclui caracteres de diferentes grupos de caracteres
 - Maiúsculas, minúsculas, algarismos, caracteres especiais
- Passwords diferentes para serviços diferentes
 - Não reutilizar passwords



Proteção de Passwords

- Passwords não devem ser armazenadas em claro
- Do lado do servidor
 - Proteção com hash
 - Combinadas com sal (salt)
 - Cifradas
- Do lado do cliente
 - Não usar passwords fracas
 - Não escrever
 - Não reutilizar
 - Guardar em cofres de passwords



Roubo de passwords

- Através de ataques a serviços com o roubo (exfiltração) dos dados dos utilizadores
 - Pode revelar as credenciais de todos os utilizadores do serviço
- Podem também ser roubadas ao utilizador:
 - Espreitando quando o utilizador a introduz (*shoulder surfing*)
 - Através de Malwares, como
 - Spywares: que recolhem dados no computador,
 - Keyloggers: que leem dados introduzidos através do teclado
 - Através de Phishing: utilizadores são encaminhados sites maliciosos (imitações de sites legítimos) onde as credenciais lhes são pedidas
 - Perda ou roubo de computadores e dispositivos de armazenamento
 - Linux: ficheiro /etc/shadow
 - Engenharia social: manipulação dos utilizadores para fornecer as suas credenciais
 - Man-in-the-middle: quando o atacante tem acesso ao canal de comunicação



Ataques de descoberta de passwords

- Força bruta: Tentativa de descobrir passwords através da verificação sistemática de todas as possibilidades
- Dicionário: Parecido com a Força Bruta, mas com a verificação limitada a passwords comuns e a palavras e frases conhecidas
- Spraying: Ataque a uma lista de contas usando um conjunto limitado de passwords frequentes
- Credential Stuffing: Injeção automática de pares de username/password conhecidos para descoberta de contas acessíveis
- Rainbow tables: tabela com hashes de passwords pré calculados para acelerar a descoberta de passwords



Algo que sou: biometria

- Dois tipos de características
 - Fisiológicas
 - Impressões digitais: sulcos da pele dos dedos (imagem)
 - Retina: capilaridade dos vasos que levam sangue à retina (varrimento de luz)
 - Íris: padrões de cor e íris (imagem)
 - Estrutura facial: características faciais (câmara)
 - Padrões vasculares: padrões nas veias da mão e dedos (infra-vermelhos)
 - Comportamentais
 - Reconhecimento de padrões de voz
 - Padrões na forma teclar
 - Padrões na forma de andar



Modelos de autenticação

- Aproximação direta
 - Apresentar credencias
 - Esperar pelo veredicto
- Aproximação com desafio-resposta
 - Obter desafio
 - Calcular e fornecer uma resposta calculada com base nas credenciais e no desafio
 - Esperar pelo veredicto



Aproximação direta com senha memorizada

- Como funciona
 - A senha é enviada pelo utilizador e confrontada com um valor guardado para a pessoa que se está a autenticar
 - Valor pessoal guardado:
 - Transformação da senha
 - Em Linux: Hash(senha + sal); guardado em /etc/shadow
 - Vantagens
 - Simplicidade
 - Problemas
 - Utilização de senhas fracas/inseguras
 - Permitem ataques com dicionários
 - Transmissão de senhas em claro através de canais inseguros
 - Escutas podem revelar senhas
 - Telnet, PAP
-



Aproximação direta com biometria

- Como funciona
 - Uma pessoa autentica-se usando medidas do seu corpo
 - Estas medidas são comparadas com um registo pré armazenado
 - Vantagens
 - As pessoas não precisam de memorizar nada
 - As pessoas não podem escolher senhas fracas
 - As credenciais não podem ser transferidas entre pessoas
 - Problemas
 - As pessoas não podem mudar de credenciais
 - As credenciais não podem ser transferidas entre pessoas
 - Pode criar riscos para as pessoas
 - Não é fácil fazer autenticação remota
 - A biometria pode revelar informação pessoal sensível
-



Aproximação direta com senhas descartáveis

- Senhas descartáveis/únicas (one-time passwords)
 - Senhas que se podem usar no máximo uma vez



Montepio24

	1	2	3	4	5	6	7	8	9
A	123	123	123	123	123	123	123	123	123
B	123	123	123	123	123	123	123	123	123
C	123	123	123	123	123	123	123	123	123
D	123	123	123	123	123	123	123	123	123
E	123	123	123	123	123	123	123	123	123
F	123	123	123	123	123	123	123	123	123
G	123	123	123	123	123	123	123	123	123
H	123	123	123	123	123	123	123	123	123

Montepio24

- Vantagens
 - Podem ser observadas.



- Problemas
 - O interlocutores precisam de saber que senha utilizar em cada ocasião
 - Implica uma qualquer forma de sincronização
 - As pessoas podem precisar de recursos extra para manter ou gerar as senhas descartáveis
 - Folha de papel, programa de computador, ...



Desafio-Resposta com senha memorizada

- Credenciais de autenticação
 - Senha selecionada pelo utente
 - O autenticador sabe
 - A senha e calcula uma transformação da senha
 - Preferencialmente unidirecional
 - Protocolo com desafio-resposta elementar
 - O autenticador gera um desafio aleatório (nonce)
 - O utente calcula uma transformação unidirecional do desafio e da senha
 - O autenticador faz o mesmo
 - Se os resultados forem iguais, a autenticação teve sucesso
 - Exemplos
 - CHAP, MS-CHAP v1/v2
-



Desafio resposta com smart cards

- Credenciais de autenticação
 - A posse do smartcard, eg. o Cartão de Cidadão
 - A posse da chave privada guardada no smartcard
 - Conhecer o PIN de acesso à chave privada
 - O autenticador sabe
 - A chave pública correspondente
 - Protocolo com desafio-resposta
 - O autenticador gera um desafio aleatório (nonce)
 - O dono do smartcard assina o desafio com a sua chave privada
 - Guardada no smartcard, protegida pelo PIN (autenticação multi-fator)
 - O autenticador decifra o resultado com a chave pública
 - Se o resultado for igual ao desafio, a autenticação teve sucesso
-



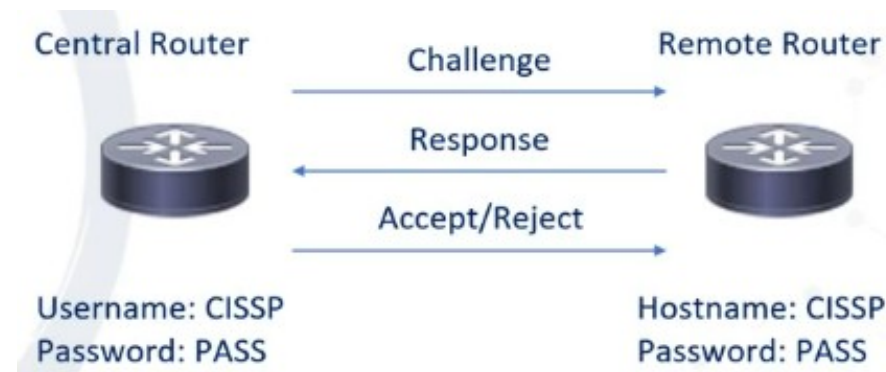
Protocolos de autenticação

- PAP (Password Authentication Protocol)
- CHAP (Challenge Handshake Authentication Protocol)
- EAP (Extensible Authentication Protocol)
- NTLM (NT LAN Manager)
- Kerberos



Protocolos de Autenticação

- PAP (Password Authentication Protocol)
 - Autenticação inicia-se no cliente através do envio das credenciais (username/password) no início da ligação
 - As credenciais são transmitidas em claro
- CHAP (Challenge-Handshake Authentication Protocol)
 - Tanto o cliente como o servidor têm de conhecer a password do cliente (em claro)
 - Um ataque ao servidor pode expor as credenciais de todos os utilizadores.
 - Tem proteção contra a repetição de mensagens
 - A password nunca é transmitida em claro





Protocolos de Autenticação

- EAP (Extensible Authentication Protocol)
 - Envolve três entidades: Suplicante, Autenticador e Servidor de Autenticação
 - Cria um túnel através do Autenticador, entre Suplicante e Servidor de Autenticação
 - Usado em redes sem fios 802.11 (Wifi)
 - Múltiplas variações do EAP
 - PEAP, EAP-MD5, LEAP, EAP-TLS, EAP-TTLS, EAP-TTLS,...
 - PEAP (Protected Extensible Authentication Protocol) é utilizado para autenticação no acesso à rede eduroam
 - NTLM (NT LAN Manager)
 - Semelhante ao CHAP com autenticação baseada em desafio-resposta
 - Passwords guardadas após hash, mas sem sal, vulneráveis a ataques por força bruta
 - Vulnerável a ataques “pass-the-hash”
 - Mantido apenas por questões de compatibilidade. Não deve ser usado.
-



Modelos de gestão de identidades

- Centralizado
 - O próprio serviço gera as identidades digitais de quem pode aceder.
- Single Sign-On
 - Permite o acesso a vários recursos de uma organização sendo necessário apenas autenticar-se uma vez
 - Exemplo: idp da universidade (idp.ua.pt)
 - IDP – Identity Provider (Fornecedor de identidade) – Serviço que gere as identidades digitais
 - O utilizador apenas se autentica uma vez e acede a várias aplicações
 - Exemplo: elearning.ua.pt, paco.ua.pt, ...
- Identidade Federada
 - Permite aos utilizadores aceder a recursos de várias organizações, com base em credenciais de outra organização
 - Identidade portátil
 - Exemplo, acesso à O'Reilly (<https://www.oreilly.com>) com credenciais da UA
 - O utilizador autentica-se no idp da UA para aceder a recursos da O'Reilly
- Tecnologias usadas em Single Sign-On e Identidade Federada:
 - SAML, OAuth 2.0, OpenID Connect, Shibboleth



Questões?

